POLITEKNIK NEGERI BENGKALIS

Jurusan Teknik Informatika · Program Studi D4 Rekayasa Perangkat Lunak

JOBSHEET 3

Secure SDLC, Attack Surface dan Threat Modeling

Nama	Nuraini
NIM	6304240055
Mata kuliah	Keamanan Perangkat Lunak
Pertemuan	3
Topik	Secure SDLC, Attack Surface & Threat Modeling
Praktikum	Analisis arsitektur login dan checkout Juice Shop: entry point, DFD, STRIDE
Output	Attack Surface Map + Threat Model (Bab 3)
Dosen pengampu	Muhammad Asep Subandri, M.Kom

A. Tujuan Praktikum

Setelah menyelesaikan jobsheet ini, mahasiswa mampu:

- Menjelaskan aktivitas keamanan pada setiap fase Secure SDLC.
- Mengidentifikasi entry point dan menyusun Attack Surface Map.
- Menggambar Data Flow Diagram (DFD) lengkap dengan trust boundary.
- Menerapkan STRIDE pada elemen DFD dan menyusun Threat Model.
- Menilai risk setiap threat dengan skala Pertemuan 2 dan menghubungkannya ke Asset & Risk Register.

B. Alat dan Bahan

Komponen	Keterangan
Target	OWASP Juice Shop (http://localhost:3000), dengan batas analisis pada fitur login dan checkout.
Pengamatan	Browser DevTools dan History pada OWASP ZAP (mode pasif).
Diagram	draw.io (diagrams.net) atau Mermaid. OWASP Threat Dragon bersifat opsional.
Masukan	Asset & Risk Register dari Bab 2 (ID aset A-xx dan risk R-xx).
Template	Tabel pada Lampiran A, B, dan C jobsheet ini.

C. Dasar Teori Singkat

1. Secure SDLC

Secure SDLC menanamkan aktivitas keamanan pada setiap fase pengembangan, bukan hanya pengujian di akhir. Prinsip shift-left: semakin awal celah ditemukan, semakin murah perbaikannya.

Fase	Aktivitas keamanan
Requirements	Security requirement dan abuse case
Design	Threat modeling dan review desain (fokus pertemuan ini)

Fase	Aktivitas keamanan
Implementation	Secure coding dan code review
Testing	SAST, SCA, DAST, penetration test
Deployment	Hardening dan review konfigurasi
Maintenance	Patch dependency dan incident response

2. Attack surface

Attack surface adalah seluruh titik tempat data atau perintah dapat masuk dan keluar dari sistem (entry point): antarmuka web, API, upload file, penyimpanan data, dependency, dan akun. Memperkecil attack surface berarti menghapus fitur yang tidak perlu, menerapkan least privilege, dan memvalidasi input di setiap entry point.

3. Threat modeling dan DFD

Threat modeling menjawab empat pertanyaan: apa yang kita bangun, apa yang bisa salah, apa yang akan kita lakukan, dan apakah sudah cukup baik. Pertanyaan pertama dijawab dengan DFD.

Elemen DFD	Keterangan
External entity (E)	Pihak di luar kendali sistem, misalnya pelanggan.
Process (P)	Kode yang mengolah data, misalnya API login.
Data store (D)	Tempat data disimpan, misalnya database.
Data flow (F)	Perpindahan data antar elemen.
Trust boundary	Batas perubahan tingkat kepercayaan. Data flow yang melewatinya adalah kandidat utama attack surface.

4. STRIDE

STRIDE adalah enam kategori ancaman. Setiap kategori melanggar satu properti keamanan.

Kategori	Properti dilanggar	Contoh pada Juice Shop
Spoofing	Authentication	Memakai identitas atau token milik orang lain
Tampering	Integrity	Mengubah harga atau jumlah pada request keranjang
Repudiation	Non-repudiation	Pelanggan menyangkal pesanan karena tidak ada log
Information disclosure	Confidentiality	Pesan error membocorkan stack trace
Denial of service	Availability	Bot membanjiri endpoint login
Elevation of privilege	Authorization	Pelanggan memanggil fungsi khusus admin

Kategori yang relevan bergantung pada jenis elemen (STRIDE per elemen):

Elemen	S	T	R	I	D	E
External entity	✓		✓			
Process	✓	✓	✓	✓	✓	✓
Data store		✓	✓ (bila ada log)	✓	✓	
Data flow		✓		✓	✓	

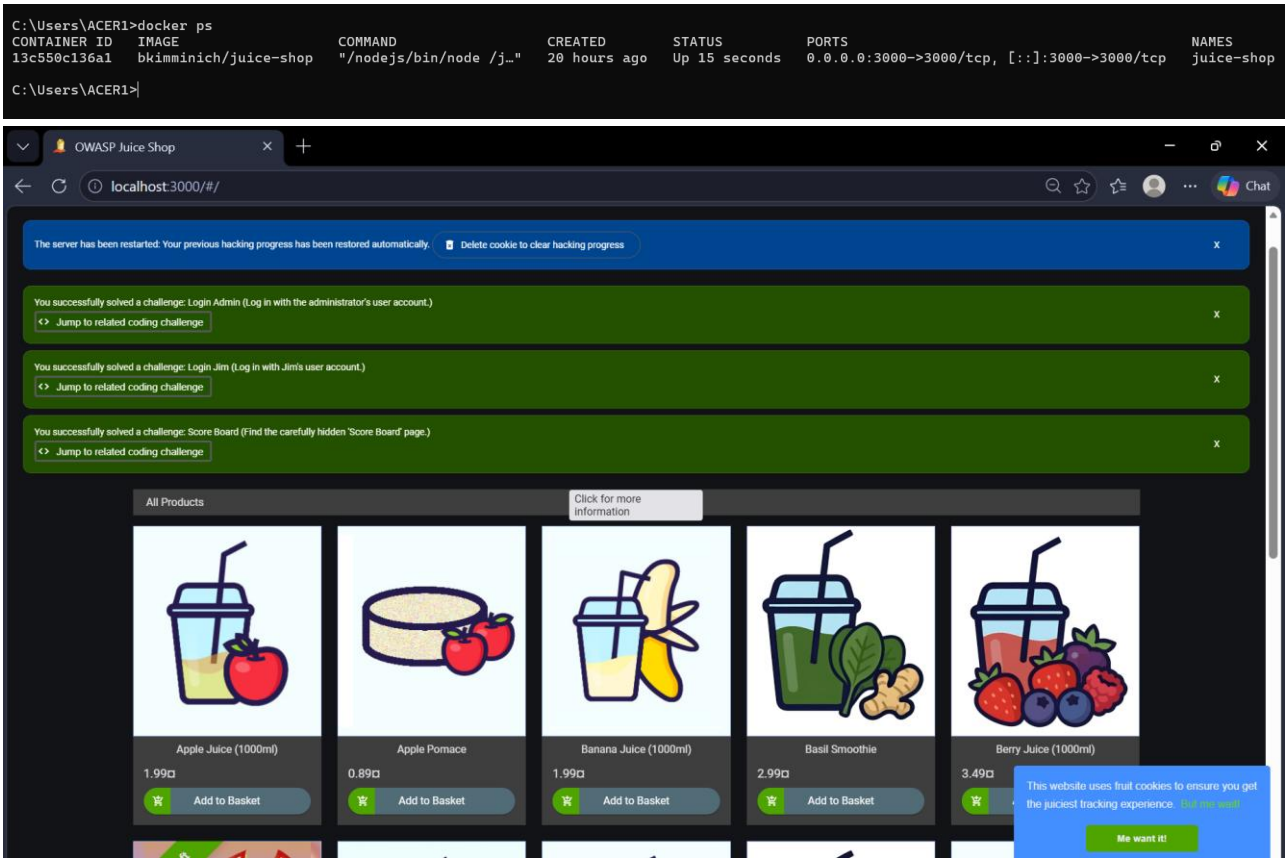
Attack surface bukan vulnerability. Entry point hanyalah pintu masuk. Threat model memetakan ancaman yang mungkin terjadi pada pintu itu, sedangkan vulnerability baru terbukti setelah diuji pada pertemuan berikutnya.

D. Langkah Praktikum

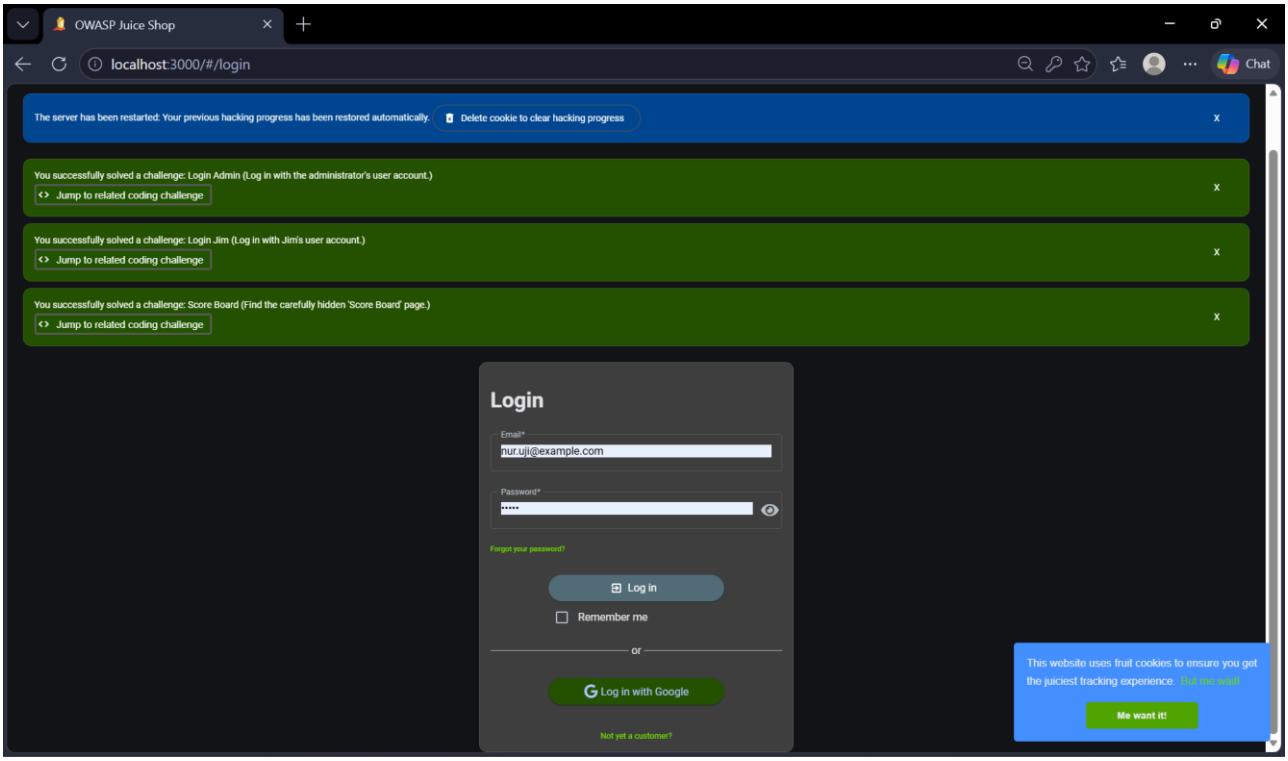
Batasan hari ini. Praktikum ini hanya **mengamati dan menganalisis**. Eksploitasi aktif belum dilakukan. Gunakan hanya Juice Shop di komputer Anda sendiri dan patuhi Rules of Engagement dari pertemuan 1. Gunakan data uji, bukan data pribadi yang nyata.

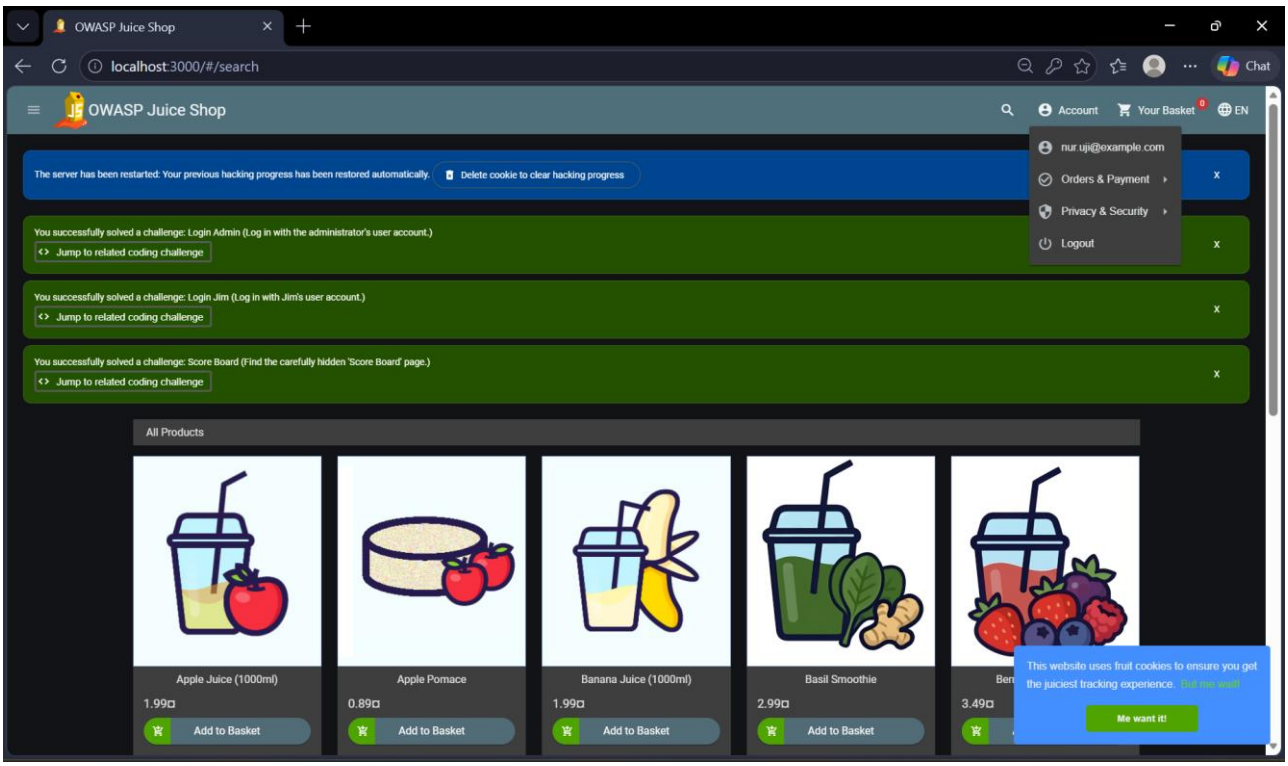
Langkah 1. Menentukan cakupan

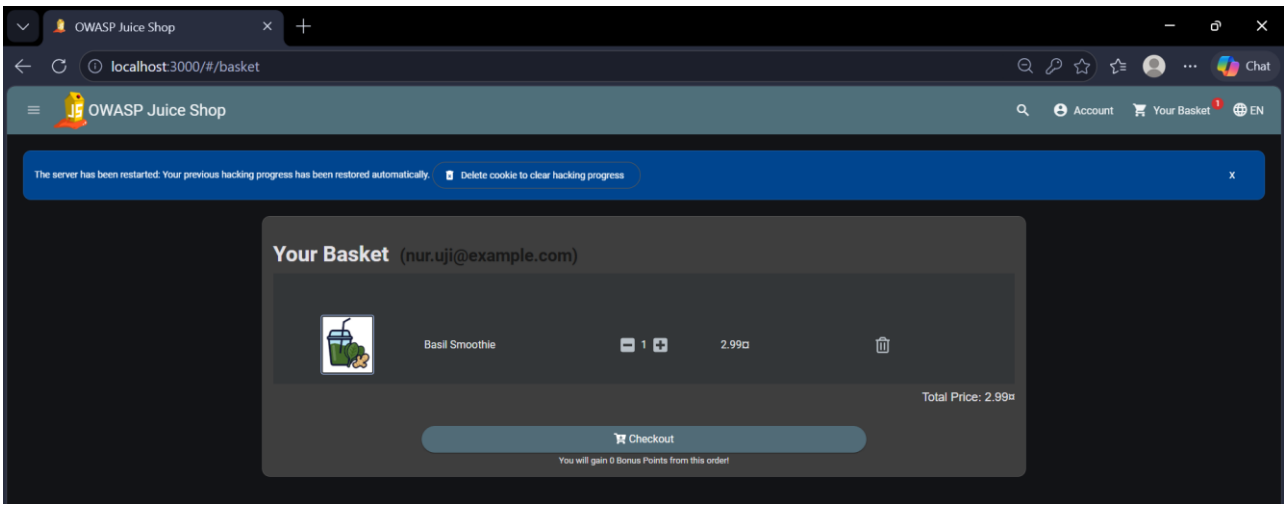
1. Pastikan container berjalan (docker ps), lalu buka http://localhost:3000.

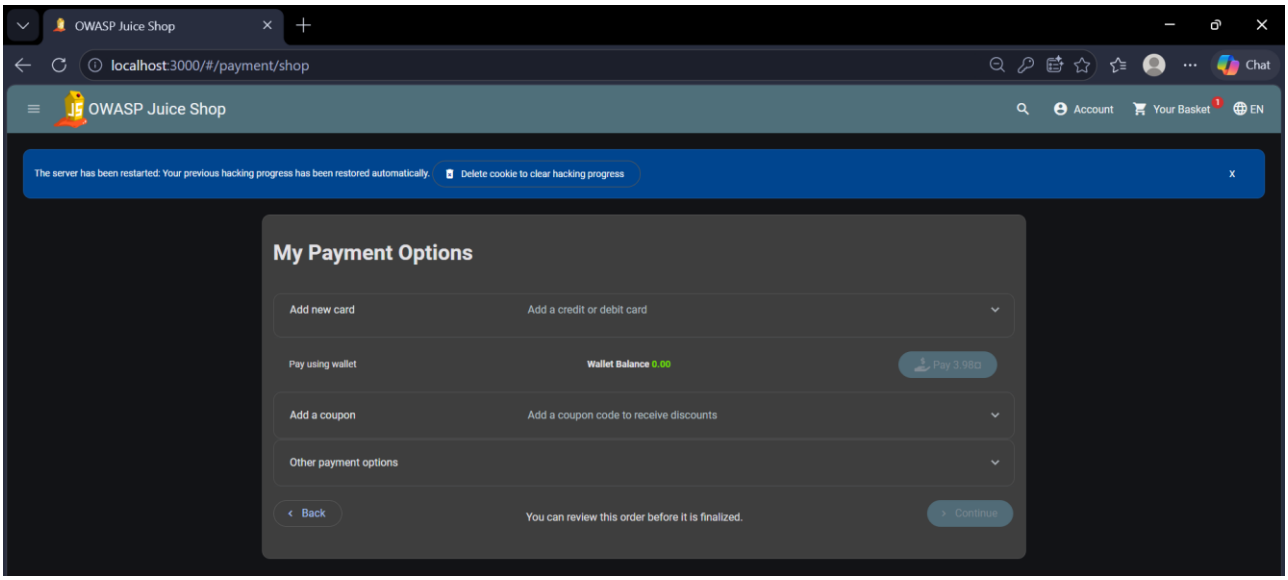


2. Login dengan akun uji milik Anda sendiri, tambahkan produk ke keranjang, lalu jalankan checkout dengan data uji.


OWASP Juice Shop
localhost:3000/#/login
Chat
The server has been restarted: Your previous hacking progress has been restored automatically.
Delete cookie to clear hacking progress
You successfully solved a challenge: Login Admin (Log in with the administrator's user account.)
Jump to related coding challenge
You successfully solved a challenge: Login Jim (Log in with Jim's user account.)
Jump to related coding challenge
You successfully solved a challenge: Score Board (Find the carefully hidden 'Score Board' page.)
Jump to related coding challenge
Login
Email*
nur.uji@example.com
Password*
Forgot your password?
Log in
Remember me
or
Log in with Google
Not yet a customer?
This website uses fruit cookies to ensure you get the juiciest tracking experience.
But me wait!
Me want it!


OWASP Juice Shop
localhost:3000/#/search
Chat
OWASP Juice Shop
Account
Your Basket
EN
nur.uji@example.com
Orders & Payment
Privacy & Security
Logout
The server has been restarted: Your previous hacking progress has been restored automatically.
Delete cookie to clear hacking progress
You successfully solved a challenge: Login Admin (Log in with the administrator's user account.)
Jump to related coding challenge
You successfully solved a challenge: Login Jim (Log in with Jim's user account.)
Jump to related coding challenge
You successfully solved a challenge: Score Board (Find the carefully hidden 'Score Board' page.)
Jump to related coding challenge
All Products
Apple Juice (1000ml)
1.99¤
Add to Basket
Apple Pomace
0.89¤
Add to Basket
Banana Juice (1000ml)
1.99¤
Add to Basket
Basil Smoothie
2.99¤
Add to Basket
3.49¤
This website uses fruit cookies to ensure you get the juiciest tracking experience.
But me wait!
Me want it!



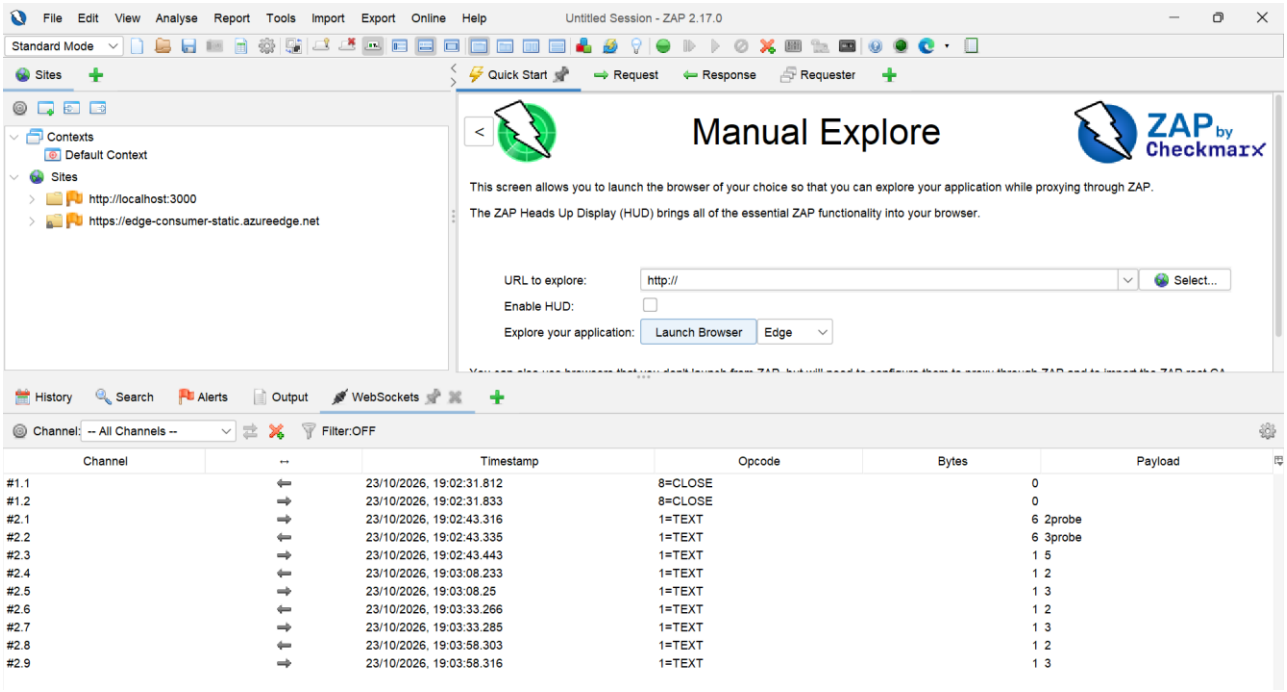


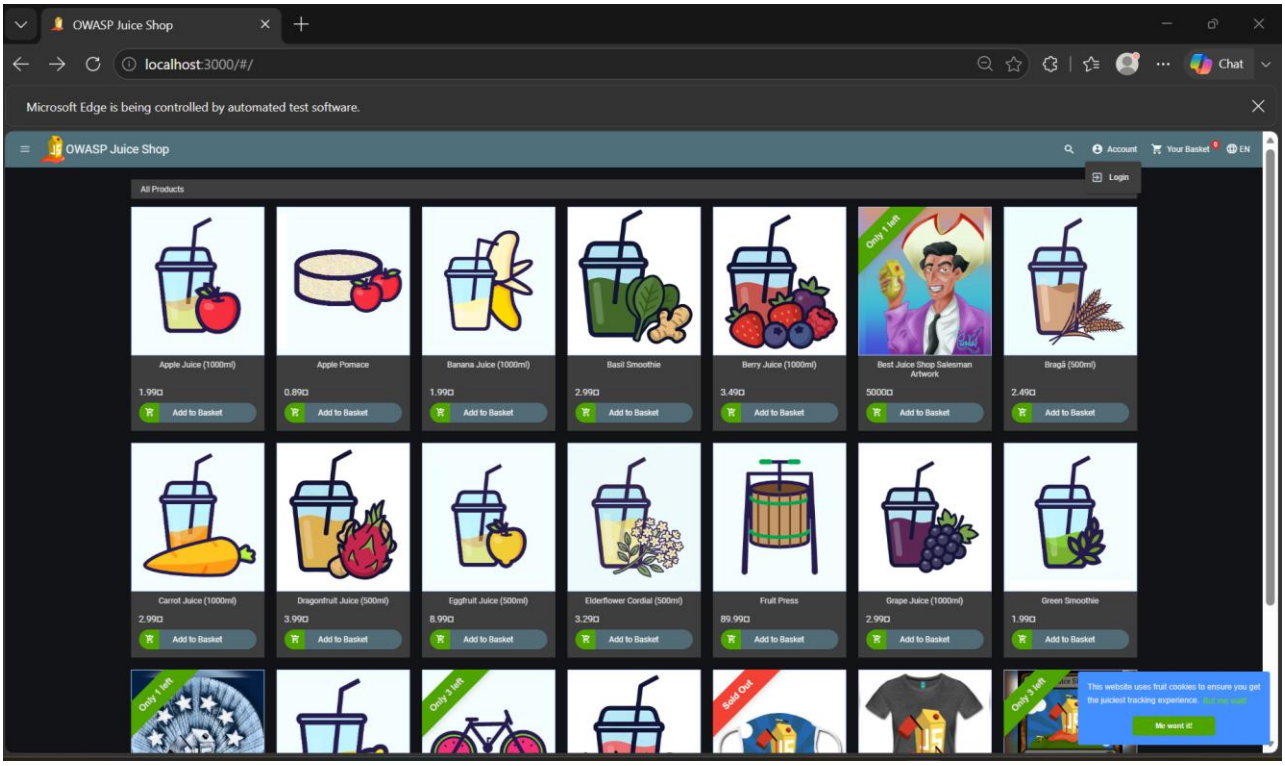
3. Tulis satu paragraf cakupan: alur yang dianalisis, aktor, dan data yang diproses. Rujuk aset dari Bab 2 yang terlibat (A-xx).

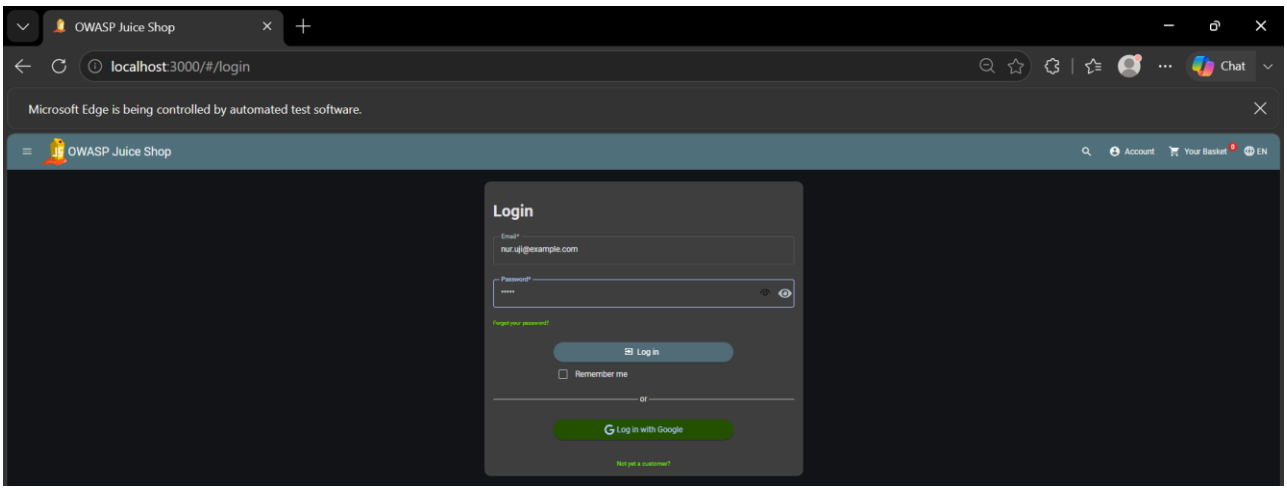
   Praktikum ini berfokus pada analisis keamanan alur login dan checkout pada aplikasi OWASP Juice Shop. Aktor yang terlibat adalah pelanggan yang mengakses aplikasi melalui browser. Alur yang dianalisis dimulai dari proses login menggunakan email dan password, pengelolaan sesi pengguna, penambahan produk ke keranjang, hingga proses checkout dan pembuatan pesanan. Data yang diproses meliputi kredensial akun, token autentikasi, informasi produk, jumlah barang, data keranjang, dan informasi pesanan. Aset yang terlibat dalam analisis ini meliputi data akun pengguna (A-01), token autentikasi dan sesi (A-02), data keranjang belanja (A-03), serta data pesanan (A-04). Analisis dilakukan untuk mengidentifikasi titik masuk sistem (*entry point*), aliran data, dan potensi ancaman keamanan menggunakan metode STRIDE.

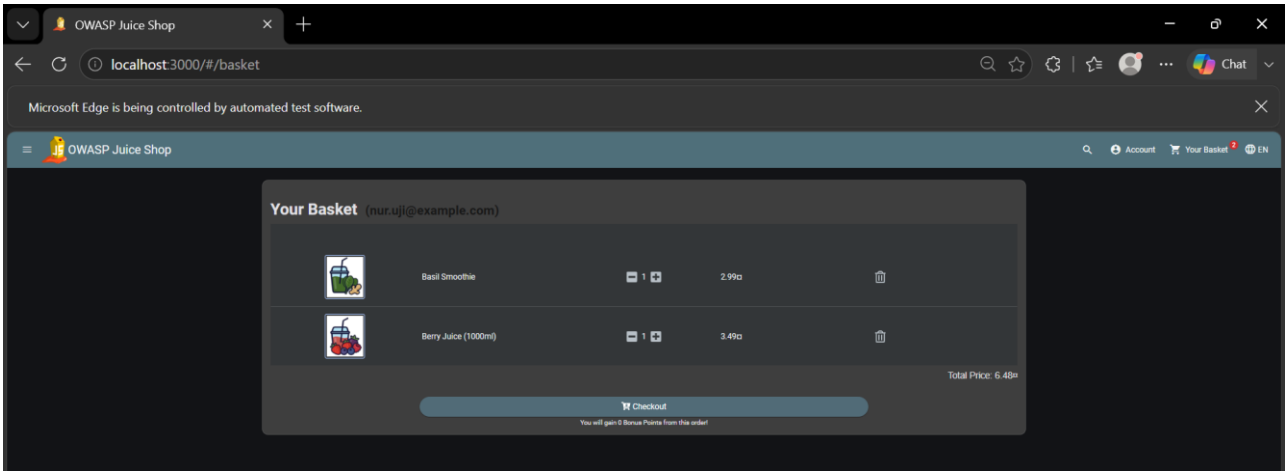
Langkah 2. Menginventaris entry point

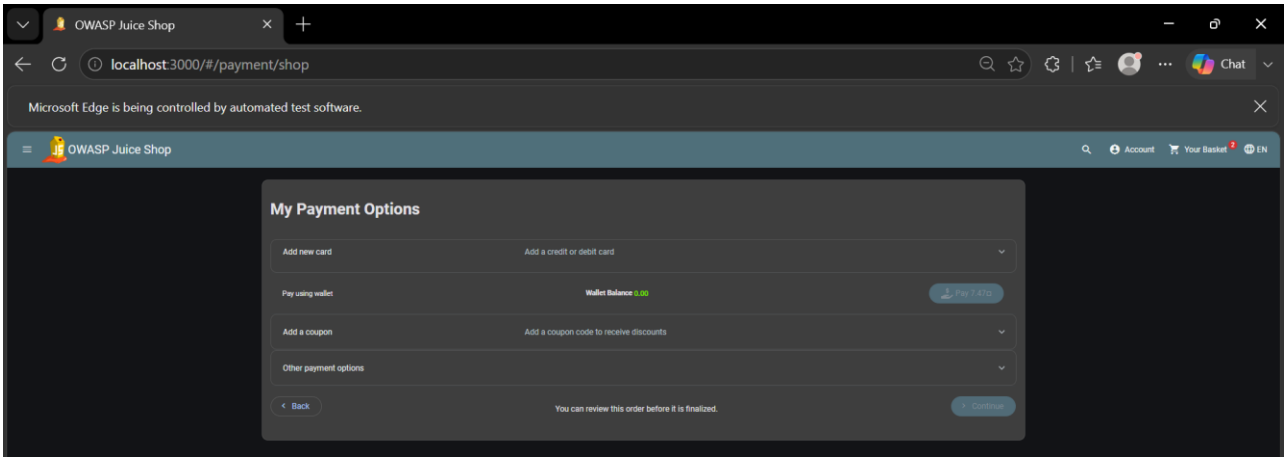
1. Jalankan ZAP lewat Launch Browser seperti pertemuan 1, lalu ulangi alur login dan checkout.


File Edit View Analyse Report Tools Import Export Online Help
Untitled Session - ZAP 2.17.0
Standard Mode
Sites
Quick Start
Request
Response
Requester
Contexts
Default Context
Sites
http://localhost:3000
https://edge-consumer-static.azureedge.net
Manual Explore
ZAP by Checkmarx
This screen allows you to launch the browser of your choice so that you can explore your application while proxying through ZAP.
The ZAP Heads Up Display (HUD) brings all of the essential ZAP functionality into your browser.
URL to explore:
http://
Select...
Enable HUD:
Explore your application:
Launch Browser
Edge
History
Search
Alerts
Output
WebSockets
Channel: -- All Channels --
Filter:OFF
Channel
Timestamp
Opcode
Bytes
Payload
#1.1 23/10/2026, 19:02:31.812 8=CLOSE 0
#1.2 23/10/2026, 19:02:31.833 8=CLOSE 0
#2.1 23/10/2026, 19:02:43.316 1=TEXT 6 2probe
#2.2 23/10/2026, 19:02:43.335 1=TEXT 6 3probe
#2.3 23/10/2026, 19:02:43.443 1=TEXT 1 5
#2.4 23/10/2026, 19:03:08.233 1=TEXT 1 2
#2.5 23/10/2026, 19:03:08.25 1=TEXT 1 3
#2.6 23/10/2026, 19:03:33.266 1=TEXT 1 2
#2.7 23/10/2026, 19:03:33.285 1=TEXT 1 3
#2.8 23/10/2026, 19:03:58.303 1=TEXT 1 2
#2.9 23/10/2026, 19:03:58.316 1=TEXT 1 3

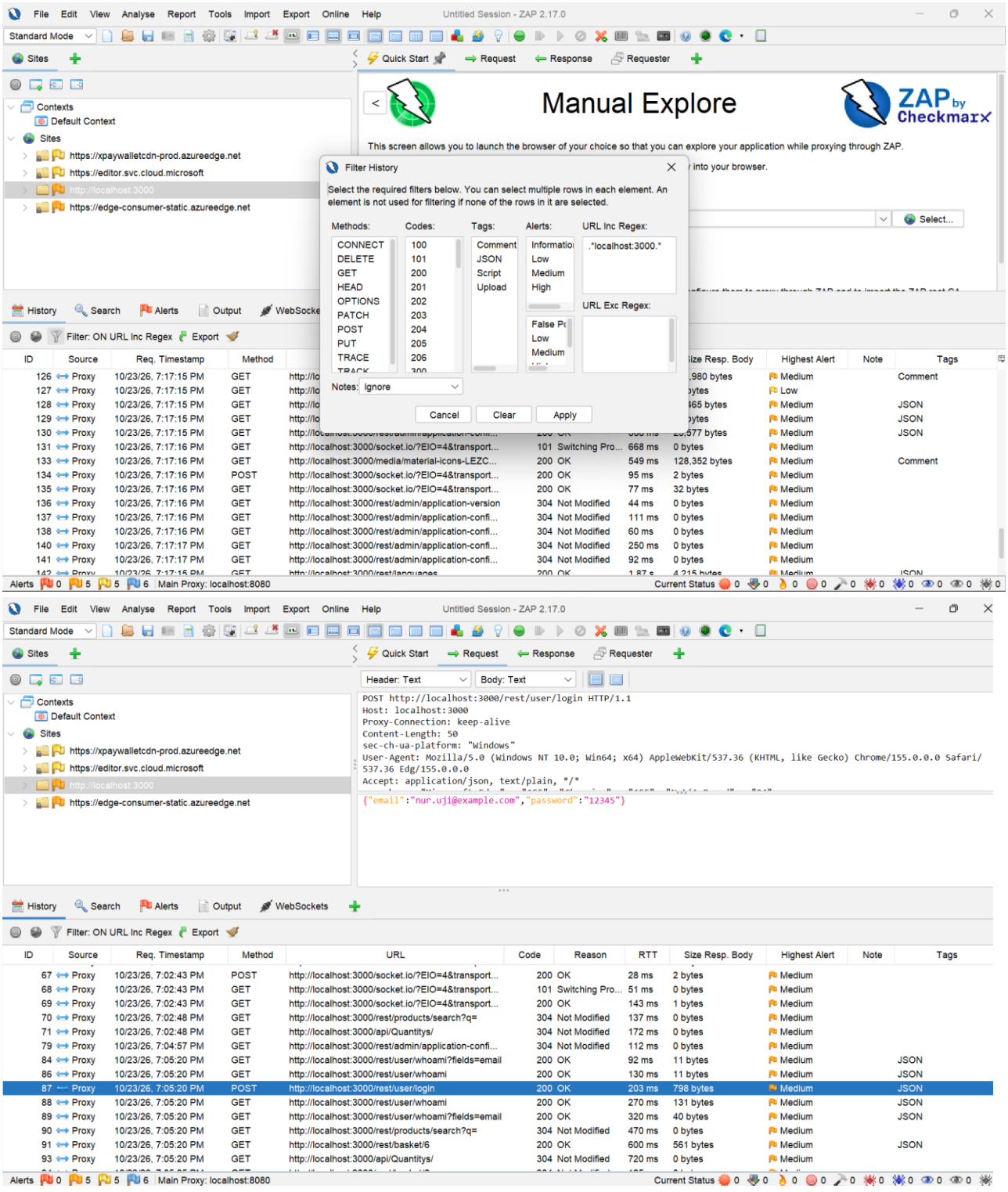

OWASP Juice Shop
localhost:3000/#/
Chat
Microsoft Edge is being controlled by automated test software.
OWASP Juice Shop
Account
Your Basket
EN
Login
All Products
Apple Juice (1000ml) 1.99¤ Add to Basket
Apple Pomace 0.89¤ Add to Basket
Banana Juice (1000ml) 1.99¤ Add to Basket
Basil Smoothie 2.99¤ Add to Basket
Berry Juice (1000ml) 3.49¤ Add to Basket
Best Juice Shop Salesman Artwork 5000¤ Add to Basket
Bragă (500ml) 2.49¤ Add to Basket
Carrot Juice (1000ml) 2.99¤ Add to Basket
Dragonfruit Juice (500ml) 3.99¤ Add to Basket
Eggfruit Juice (500ml) 8.99¤ Add to Basket
Elderflower Cordial (500ml) 3.29¤ Add to Basket
Fruit Press 89.99¤ Add to Basket
Grape Juice (1000ml) 2.99¤ Add to Basket
Green Smoothie 1.99¤ Add to Basket
Only 1 left
Sold Out
This website uses fruit cookies to ensure you get the juiciest tracking experience.
Me want it!







2. Pada tab History, saring request ke localhost:3000. Catat metode, URL, data yang dikirim, dan apakah request memerlukan login.

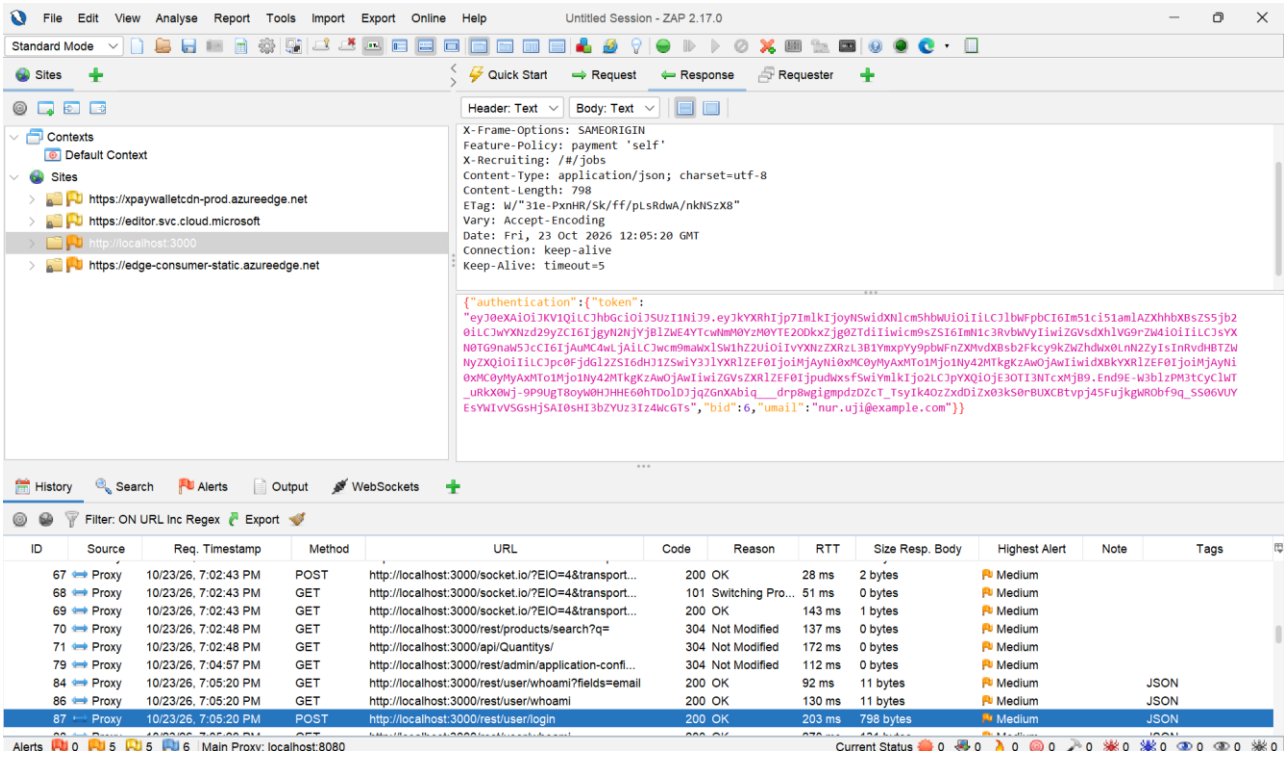


3. Tambahkan entry point dari antarmuka (form, kolom input, parameter URL). Isi Lampiran A dengan **minimal 10 entry point**.

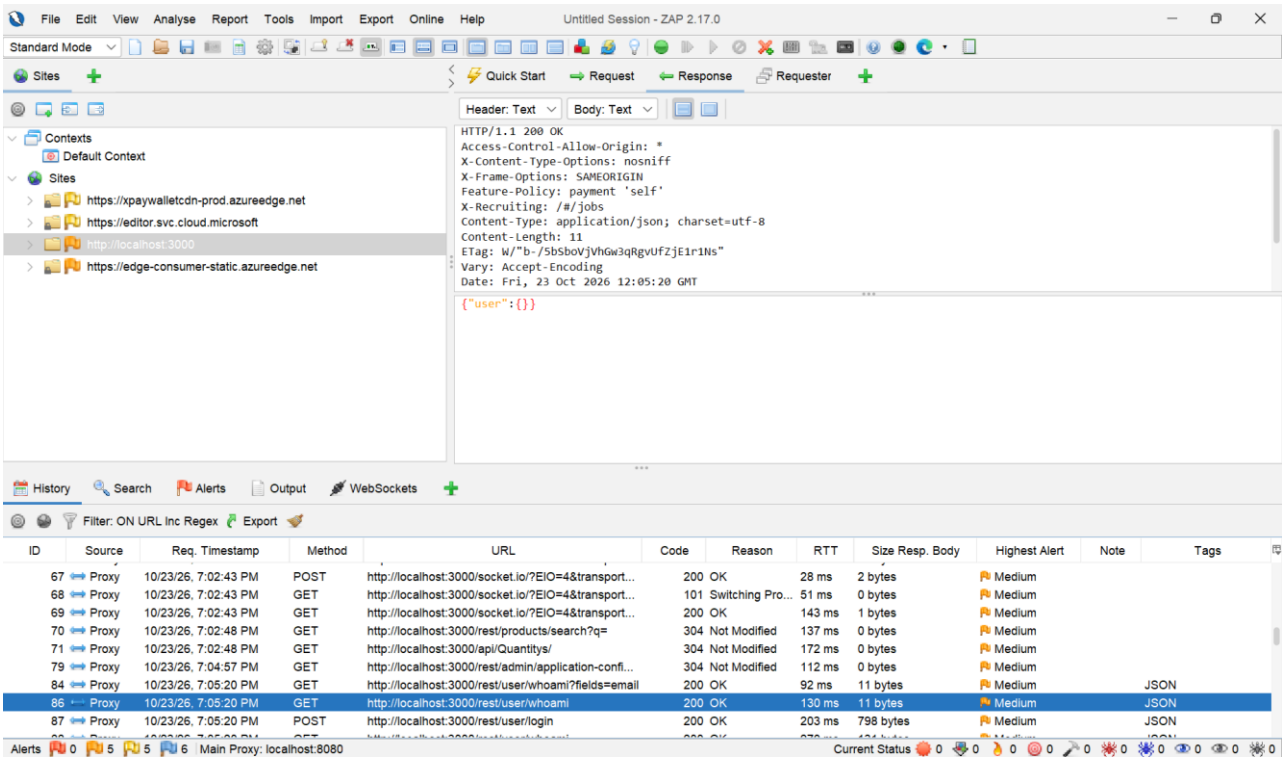
Contoh pola yang mungkin Anda temukan (verifikasi pada History Anda, jangan disalin tanpa bukti):

```
# Entry point; data/parameter; keterangan autentikasi

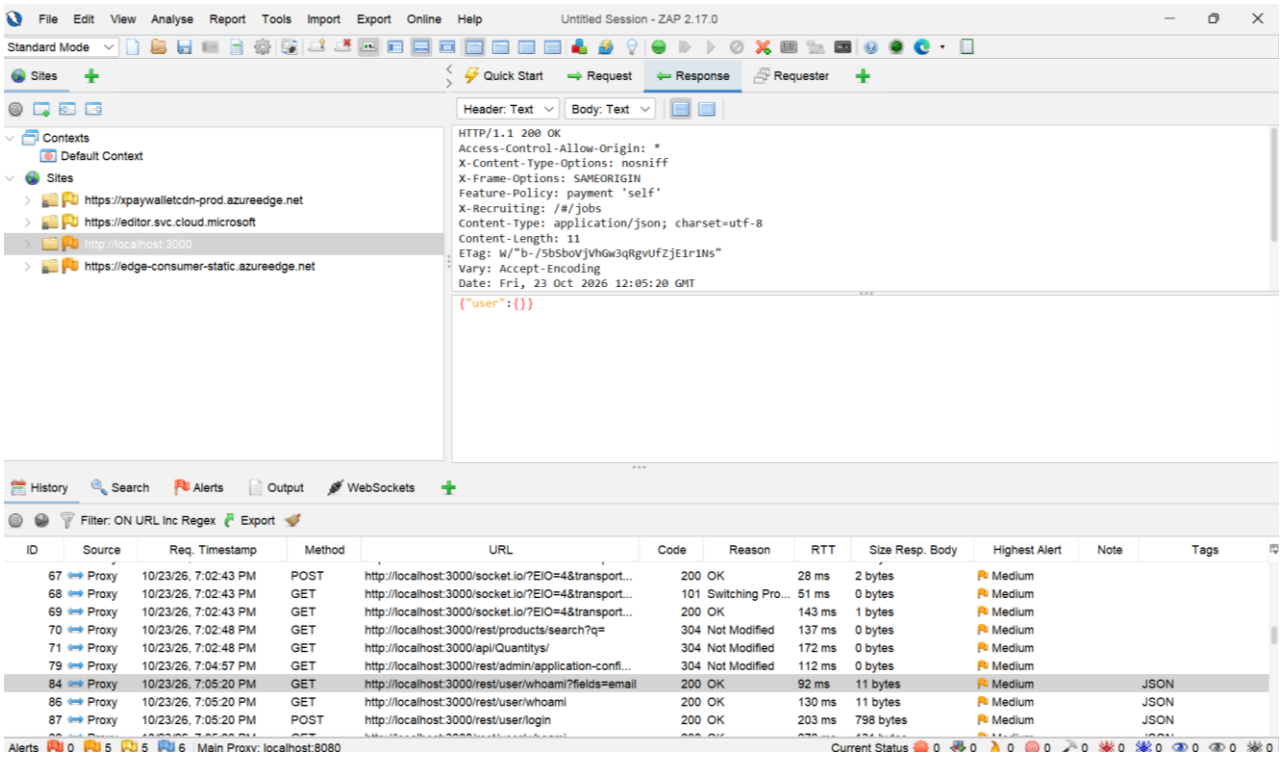
POST /rest/user/login
    -> email dan password (JSON), untuk autentikasi, tanpa token sebelumnya
```




```
GET /rest/user/whoami
    -> parameter fields=email, untuk mengambil identitas pengguna
```

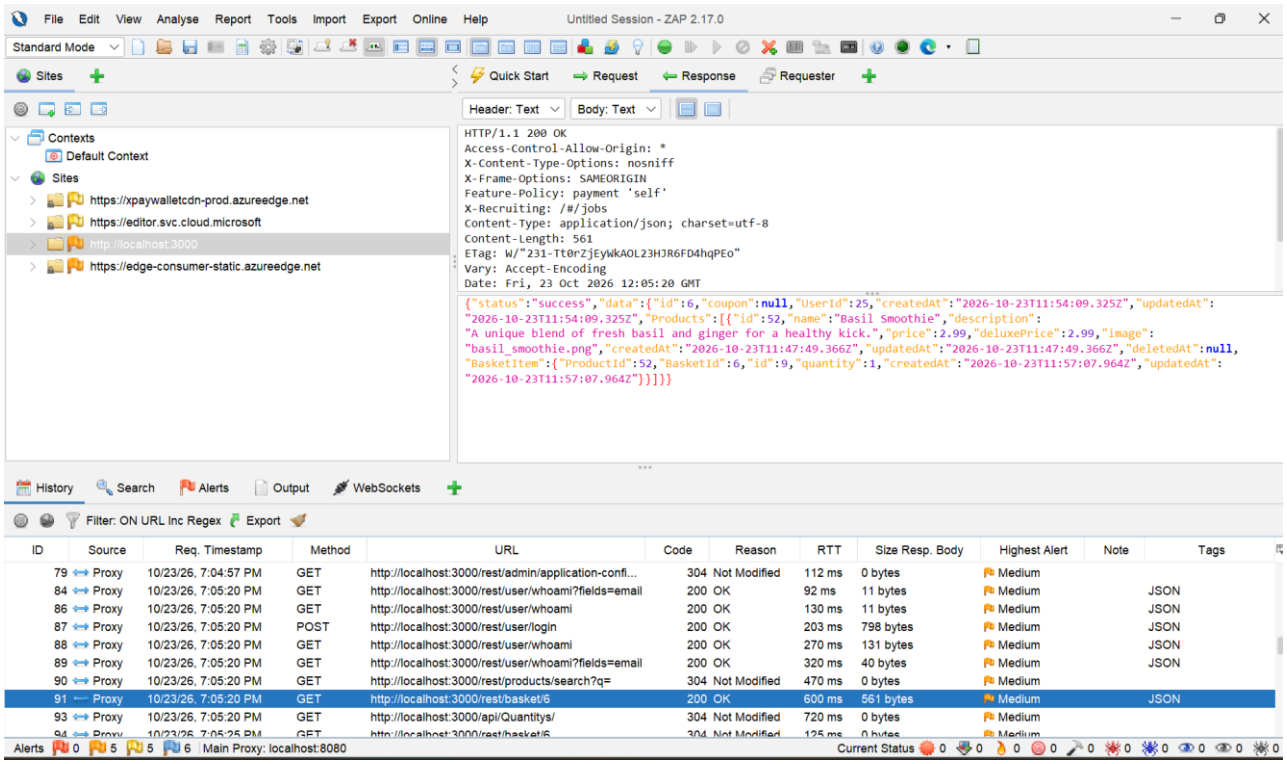



```
GET /rest/user/whoami?fields=email
    -> parameter URL fields=email, memeriksa identitas pengguna
```



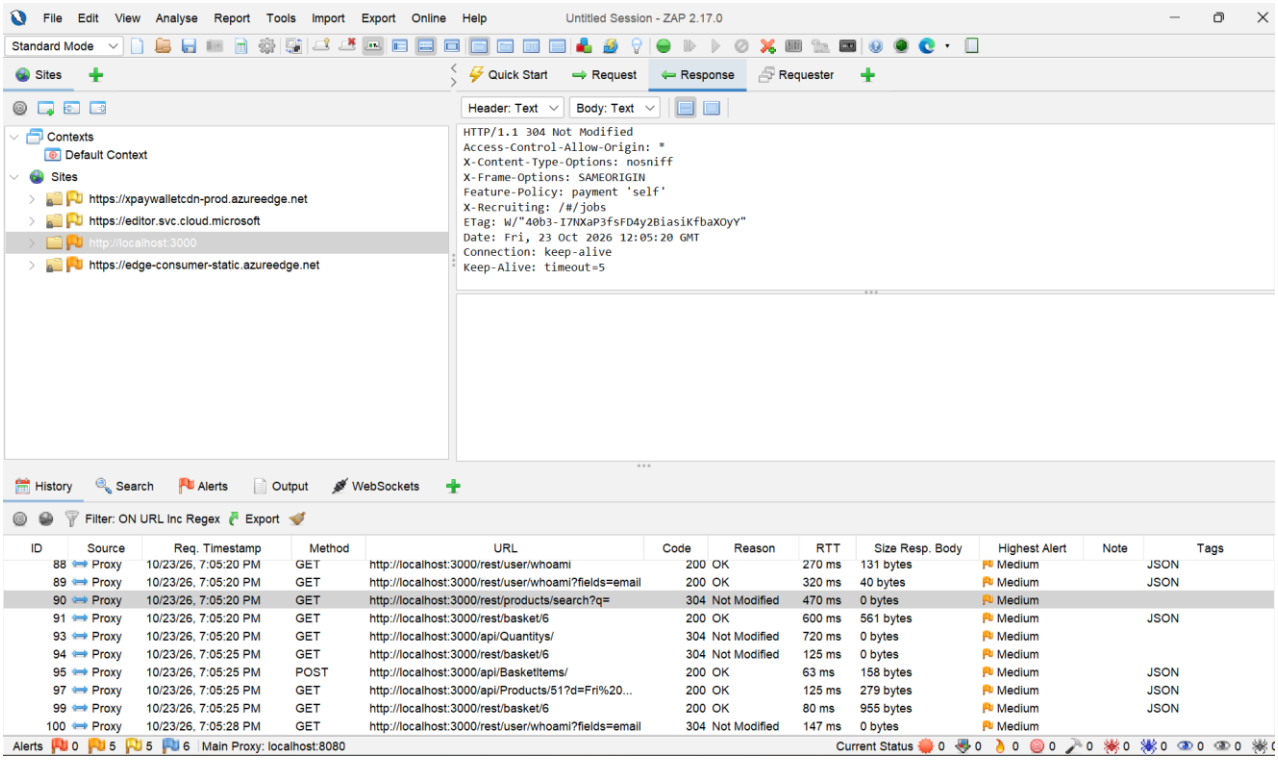
GET /rest/basket/6

-> identifier basket pada URL, memeriksa isi keranjang



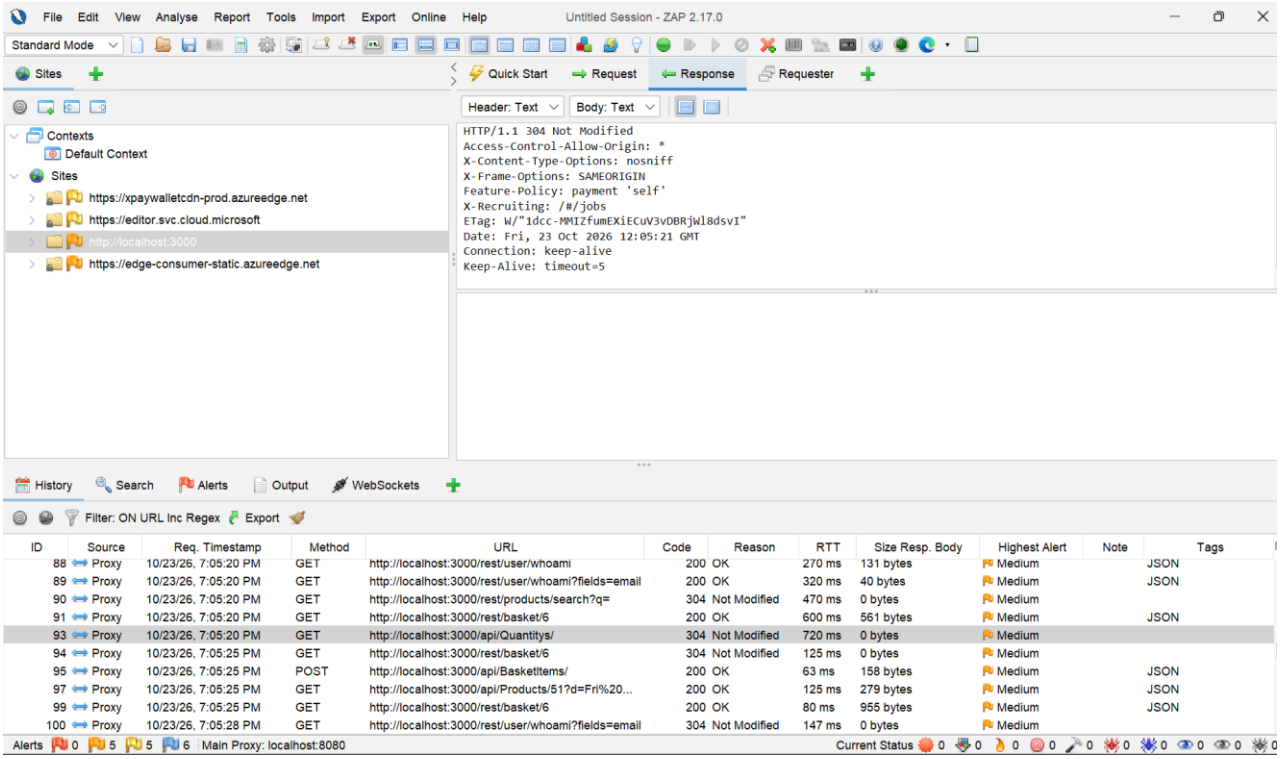
GET /rest/products/search?q=

-> parameter pencarian q pada URL



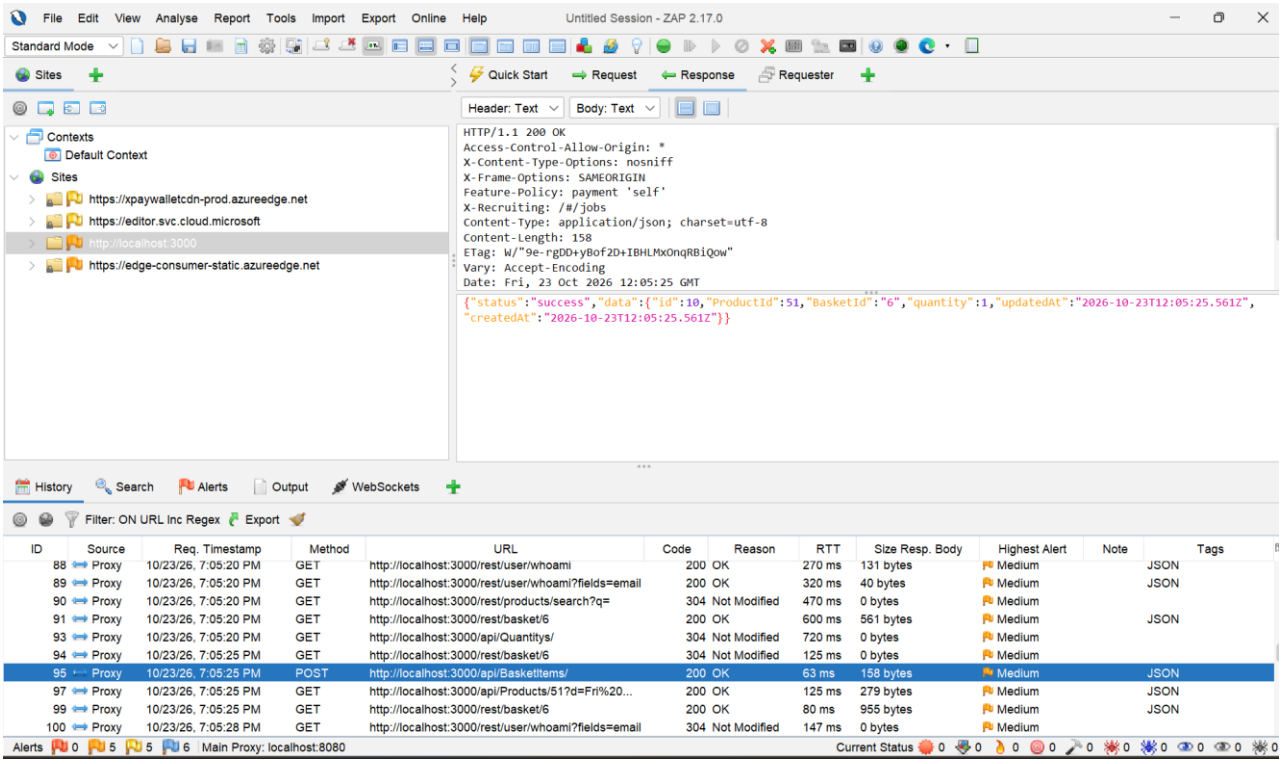
GET /api/Quantities/

-> mengambil data jumlah/kuantitas produk



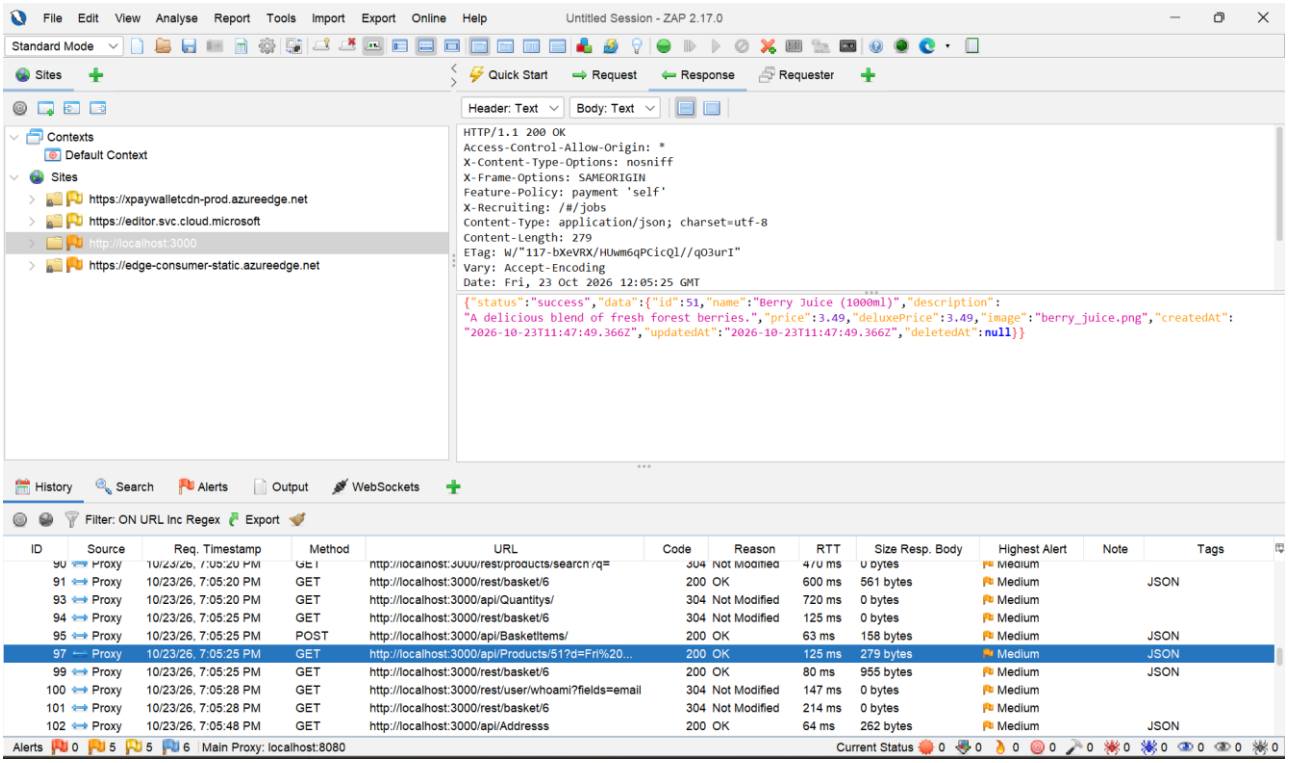
POST /api/BasketItems/

-> data item keranjang dikirim melalui request



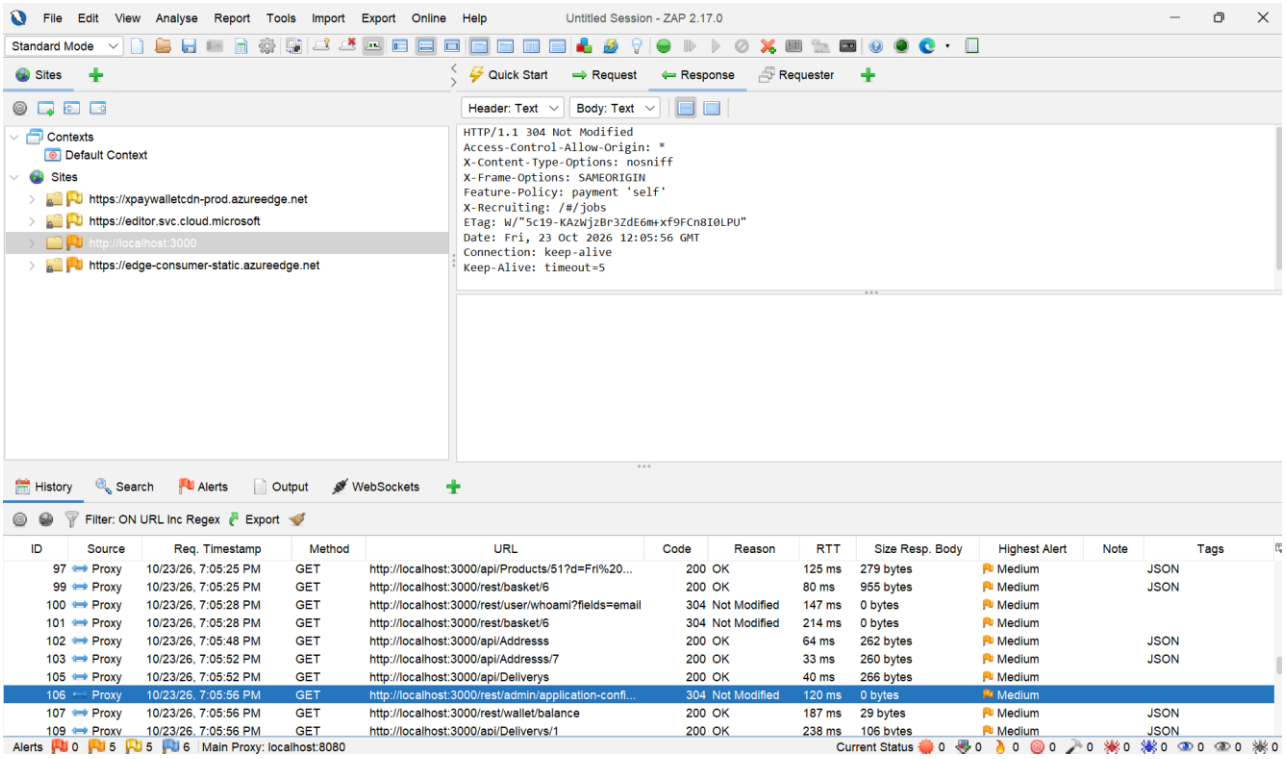
`GET /api/Products/51`

`-> identifier produk pada URL`



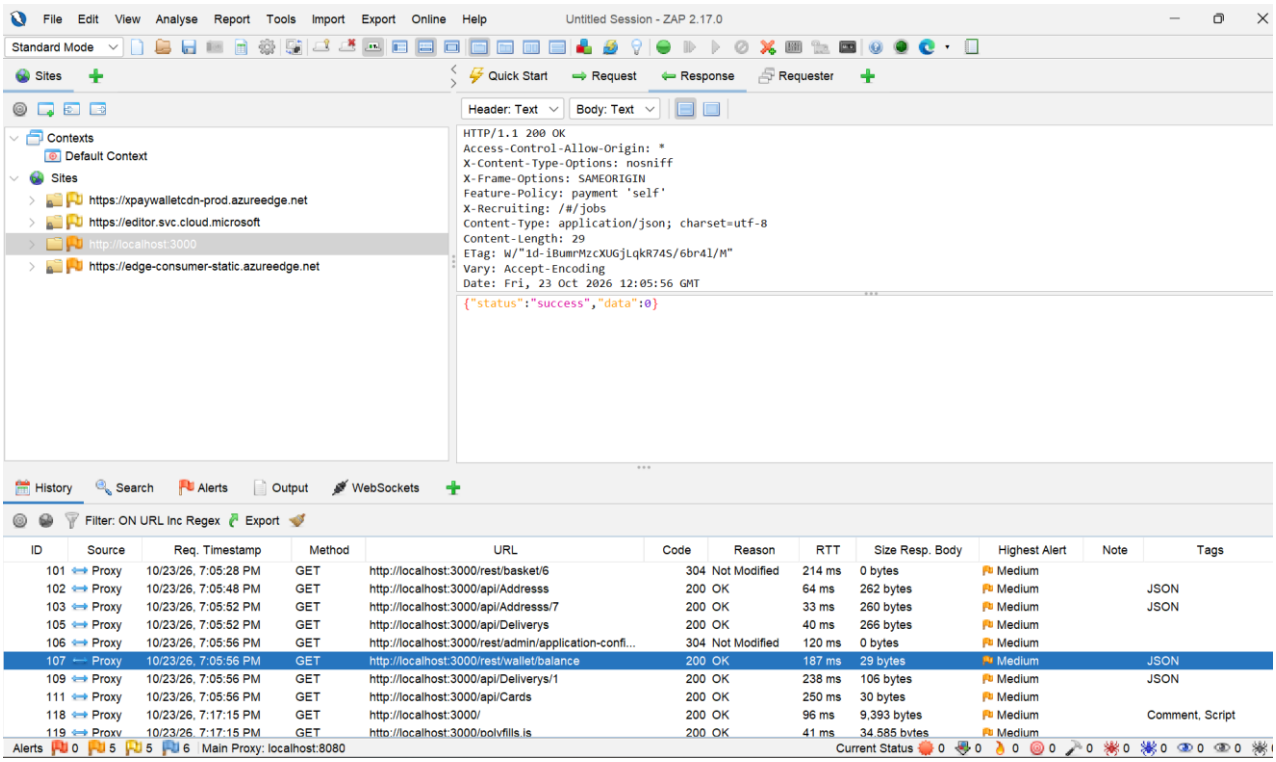
`GET /rest/admin/application-configuration`

`-> mengambil konfigurasi aplikasi; kebutuhan autentikasi perlu diverifikasi`



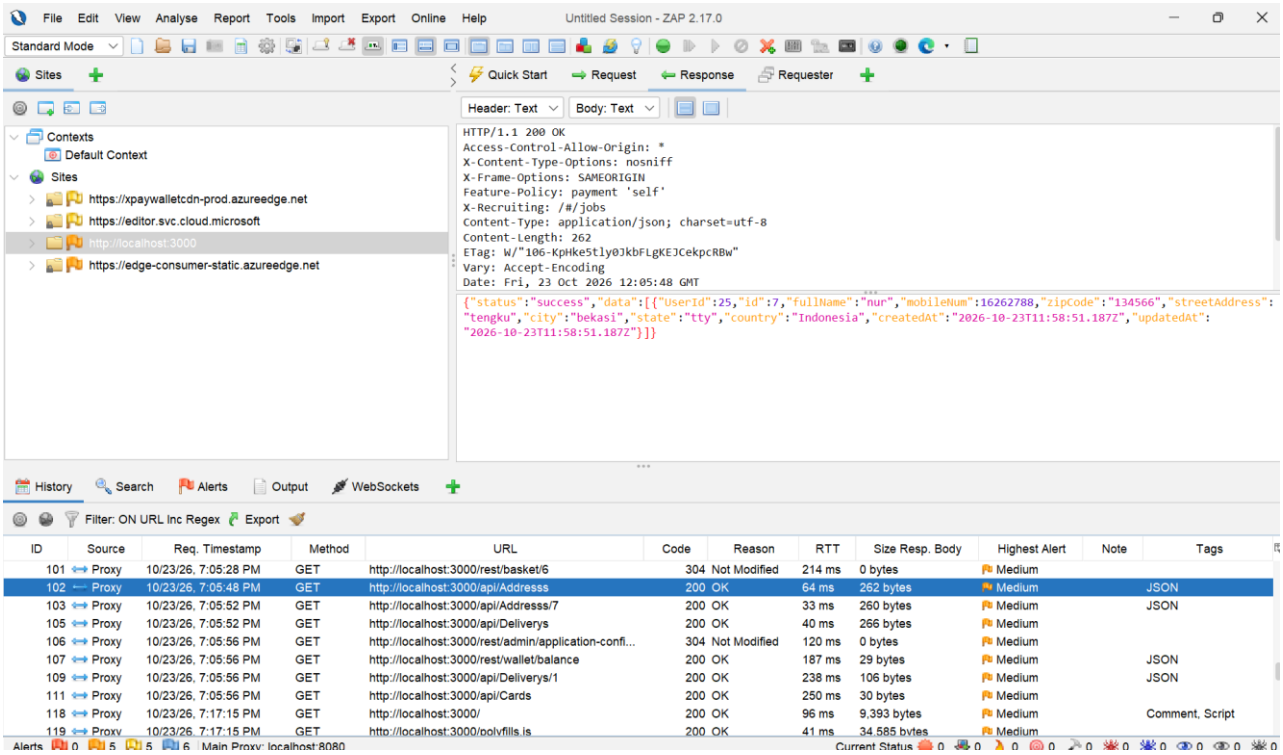
`GET /rest/wallet/balance`

`-> mengambil informasi saldo; kebutuhan autentikasi perlu diverifikasi`



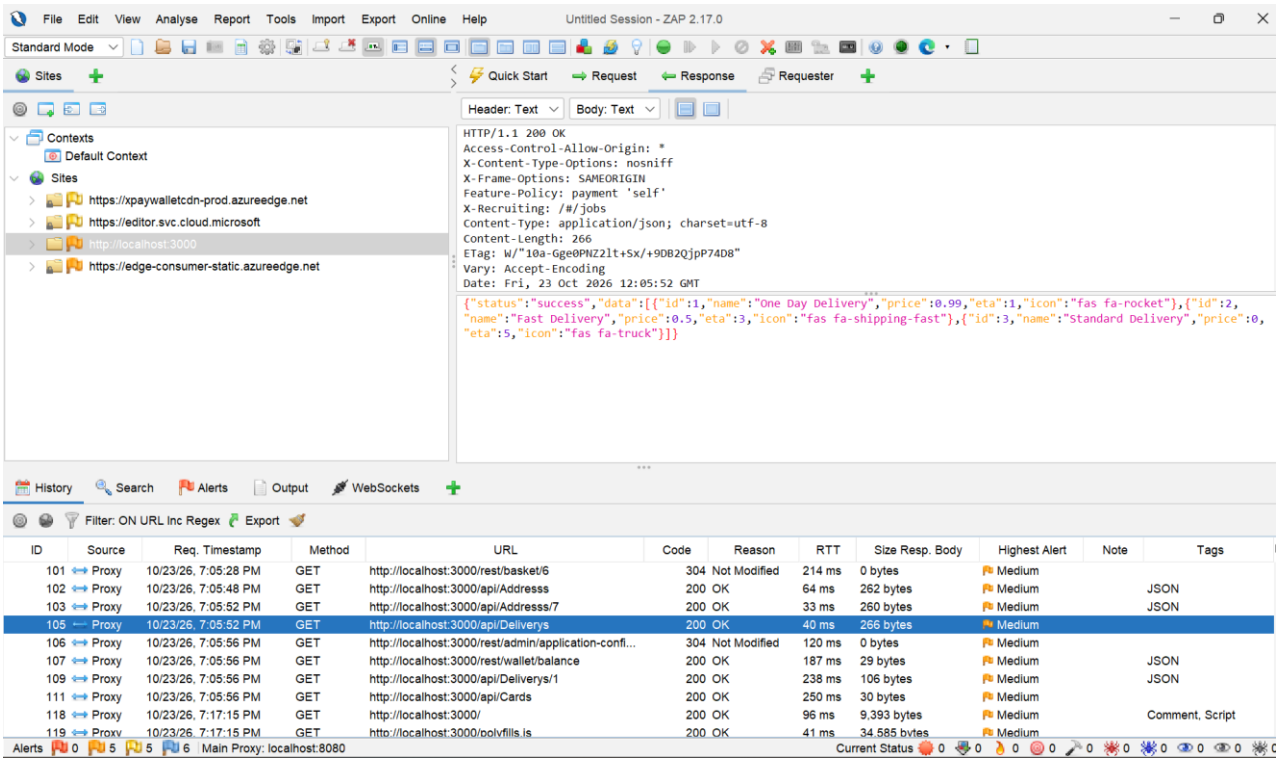
`GET /api/Addressess`

`-> mengambil daftar alamat; kebutuhan autentikasi perlu diverifikasi`



`GET /api/Deliverys`

`-> mengambil pilihan pengiriman; kebutuhan autentikasi perlu diverifikasi`



Langkah 3. Menggambar DFD

1. Tentukan elemen E, P, D, dan F, beri ID berurutan (E1, P1, D1, F1, dan seterusnya), lalu isi Lampiran B.

2. Gambar DFD level 1 di draw.io atau Mermaid. Sertakan **minimal satu trust boundary**.
3. Tandai setiap data flow yang melewati trust boundary.

Kerangka Mermaid sebagai titik awal (ubah sesuai temuan Anda):

```
%% DFD level 1: kerangka contoh, sesuaikan dengan temuan Anda
flowchart LR
  E1[E1 Pelanggan]                  %% external entity
  subgraph SERVER[Zona server]      %% trust boundary
    P1((P1 Login))                  %% process
    D1[(D1 Data akun)]              %% data store
  end
  E1 -- F1 kredensial --> P1        %% data flow lintas boundary
  P1 -- F3 query akun --> D1
```

Langkah 4. Menerapkan STRIDE

1. Untuk setiap elemen DFD, tinjau kategori STRIDE yang relevan menurut tabel STRIDE per elemen.
2. Tulis threat sebagai kalimat konkret (siapa melakukan apa pada elemen mana). Isi Lampiran C dengan **minimal 12 threat** yang mencakup **minimal 5 dari 6 kategori**.
3. Kaitkan setiap threat dengan aset (A-xx) dan, bila relevan, dengan risk R-xx dari Bab 2.

Langkah 5. Menilai risk dan menentukan respons

1. Beri Likelihood (1-5) dan Impact (1-5) dengan alasan singkat, lalu hitung skor L × I (Rendah 1-4, Sedang 5-9, Tinggi 10-14, Kritis 15-25).
2. Pilih respons: mitigate, accept, transfer, atau avoid. Untuk mitigate, tulis kontrol yang diusulkan.
3. Urutkan threat dari skor tertinggi.

Langkah 6. Refleksi

Tulis 3-4 kalimat: apa yang dapat ditemukan threat modeling pada fase desain yang sulit ditemukan setelah kode selesai?

E. Output dan Pengumpulan

Seluruh output menjadi **Bab 3** pada laporan berjalan. Kumpulkan dalam satu file PDF dengan nama NIM_Nama_Bab3.pdf.

No	Bagian laporan	Isi
1	Cakupan sistem	Satu paragraf: alur, aktor, data, dan aset terkait.
2	Attack Surface Map	Minimal 10 entry point (Lampiran A).
3	DFD	Gambar level 1 dengan ID elemen dan trust boundary, plus tabel Lampiran B.
4	Threat Model	Minimal 12 threat STRIDE dengan risk (Lampiran C).
5	Refleksi	3-4 kalimat.

F. Rubrik Penilaian

Komponen	Kriteria utama	Bobot
Cakupan sistem	Jelas, sesuai alur yang diamati	10
Attack Surface Map	Minimal 10 entry point, didukung bukti History atau DevTools	20
DFD	Elemen lengkap dan bernomor, trust boundary benar	25
Threat Model STRIDE	Minimal 12 threat, kategori tepat, risk L × I konsisten, respons jelas	30
Refleksi dan kerapian	Pemahaman tepat, laporan rapi	15

Komponen	Kriteria utama	Bobot
Total		100

G. Pemecahan Masalah dan Referensi

Masalah	Penyebab umum	Penanganan
Request tidak muncul di ZAP History	Browser melewati proxy untuk localhost	Gunakan browser dari Launch Browser pada ZAP.
Bingung menentukan trust boundary	Batas kepercayaan belum jelas	Tanyakan: siapa yang mengendalikan sisi ini? Browser pengguna tidak tepercaya.
Threat terlalu umum	Tidak menyebut aktor dan elemen	Tulis ulang: siapa, melakukan apa, pada elemen mana.

- Shostack, A. Threat Modeling: Designing for Security. Wiley.
- OWASP Threat Modeling Cheat Sheet (cheatsheetseries.owasp.org).
- NIST SP 800-218, Secure Software Development Framework (SSDF).
- Microsoft, STRIDE dan Security Development Lifecycle (learn.microsoft.com).
- NIST SP 800-30 dan OWASP Risk Rating Methodology (rujukan skala risk).

Satu paragraf: alur, aktor, data, dan aset terkait.

Cakupan Sistem

Praktikum ini berfokus pada analisis keamanan alur login dan checkout pada aplikasi OWASP Juice Shop. Aktor yang terlibat adalah pelanggan yang mengakses aplikasi melalui browser. Alur sistem dimulai dari pelanggan memasukkan email dan password untuk login, menerima token autentikasi, mencari produk, menambahkan produk ke keranjang, hingga melakukan checkout dan memproses pesanan. Data yang terlibat meliputi kredensial akun, token autentikasi, informasi produk, jumlah barang, data keranjang, dan informasi pesanan. Aset yang dianalisis meliputi A-01 data akun, A-02 token autentikasi, A-03 data keranjang, dan A-04 data pesanan. Analisis dilakukan untuk mengidentifikasi entry point, aliran data, trust boundary, dan potensi ancaman keamanan menggunakan metode STRIDE.

Lampiran A. Template Attack Surface Map

ID	Entry point (URL / form)	Metode	Data masuk	Perlu login
AS-01	/rest/user/login	POST	email, password	Tidak
AS-02	/rest/user/whoami	GET	Parameter fields=email	Perlu diverifikasi
AS-03	/rest/user/whoami?fields=email	GET	fields=email pada URL	Perlu diverifikasi
AS-04	/rest/products/search?q=	GET	Parameter pencarian q	Perlu diverifikasi
AS-05	/rest/basket/6	GET	ID keranjang 6 pada URL	Perlu diverifikasi
AS-06	/api/Quantities/	GET	Permintaan data kuantitas	Perlu diverifikasi
AS-07	/api/BasketItems/	POST	Data item keranjang	Perlu diverifikasi
AS-08	/api/Products/51	GET	ID produk 51 pada URL	Perlu diverifikasi
AS-09	/rest/admin/application-configuration	GET	Permintaan konfigurasi aplikasi	Perlu diverifikasi
AS-10	/rest/wallet/balance	GET	Permintaan informasi saldo	Perlu diverifikasi
AS-11	/api/Addressess	GET	Permintaan daftar alamat	Perlu diverifikasi
AS-12	/api/Deliverys	GET	Permintaan pilihan pengiriman	Perlu diverifikasi

No.	Entry Point Antarmuka	Data yang Dimasukkan
13	Form login	Email dan password
14	Kolom pencarian produk	Kata kunci pencarian
15	Tombol tambah produk ke keranjang	Produk dan jumlah barang
16	Form alamat pengiriman	Data alamat pelanggan
17	Pilihan metode pengiriman	Metode pengiriman
18	Form pembayaran saat checkout	Data pembayaran yang diperlukan

Lampiran B. Template Elemen DFD

ID	Tipe	Nama elemen	Trust zone
E1	External entity	Pelanggan (browser)	Tidak tepercaya
P1	Process	Login dan sesi	Server
P2	Process	Mengelola Keranjang	Menampilkan dan memperbarui isi keranjang
P3	Process	Checkout	Memproses pesanan pelanggan
D1	Data Store	Data Akun	Menyimpan data akun pengguna
D2	Data Store	Data Produk	Menyimpan informasi produk
D3	Data Store	Data Keranjang	Menyimpan item dalam keranjang
D4	Data Store	Data Pesanan	Menyimpan informasi pesanan
F1	Data Flow	Kredensial	Email dan password dari pelanggan
F2	Data Flow	Token Autentikasi	Token yang diterima setelah login
F3	Data Flow	Data Produk	Informasi produk yang diminta
F4	Data Flow	Data Keranjang	Informasi item dalam keranjang
F5	Data Flow	Data Checkout	Data yang diperlukan untuk checkout
F6	Data Flow	Informasi Pesanan	Hasil pemrosesan pesanan

Lampiran C. Template Threat Model

ID	Elemen	STRIDE	Threat	Aset / R-xx	L	I	Skor	Respons dan mitigasi
TM-01	P1 (F1)	S	Penyerang mencoba banyak password pada login	A-01 / R-01	4	4	16 Kritis	Mitigate: rate limiting, lockout, MFA

ID	Elemen	STRIDE	Threat	Aset / R-xx	L	I	Skor	Respons dan mitigasi
TM-02	P1 (F1)	S	Penyerang mencoba menggunakan kredensial akun milik pengguna lain.	A-01 / R-02	3	4	12 High	Mitigate: validasi login, pembatasan percobaan login
TM-03	P1 (F2)	I	Token autentikasi terekspos dan berpotensi digunakan pihak lain.	A-02 / R-03	3	5	15 Kritis	Mitigate: lindungi token, gunakan HTTPS, hindari pencatatan token
TM-04	P1 (F2)	S	Token yang dicuri digunakan untuk menyamar sebagai pengguna.	A-02 / R-04	2	5	10 High	Mitigate: masa berlaku token, pencabutan token, penyimpanan aman
TM-05	P2 (F4)	T	Data item atau jumlah barang pada keranjang diubah tanpa validasi yang memadai.	A-03 / R-05	3	4	12 High	Mitigate: validasi sisi server dan pemeriksaan jumlah barang
TM-06	P2 (F4)	I	Pengguna berpotensi mengakses isi keranjang milik pengguna lain.	A-03 / R-06	2	4	8 Medium	Mitigate: pemeriksaan kepemilikan keranjang dan otorisasi
TM-07	P3 (F5)	T	Data checkout atau detail pesanan diubah sebelum diproses server.	A-04 / R-07	3	5	15 Kritis	Mitigate: validasi server dan perhitungan ulang total pesanan
TM-08	P3 (F6)	R	Pengguna menyangkal telah melakukan pemesanan karena catatan transaksi tidak memadai.	A-04 / R-08	2	4	8 Medium	Mitigate: audit log dan pencatatan waktu transaksi
TM-09	P3 (F5)	E	Pengguna mencoba mengakses fungsi checkout atau administrasi di luar hak aksesnya.	A-04 / R-09	2	5	10 High	Mitigate: pemeriksaan otorisasi berbasis peran
TM-10	P1 (F1)	D	Permintaan login berulang berpotensi membebani layanan.	A-01 / R-10	3	3	9 Medium	Mitigate: rate limiting dan pemantauan trafik
TM-11	P3 (F5)	D	Permintaan checkout berulang berpotensi mengganggu ketersediaan layanan.	A-04 / R-11	2	4	8 Medium	Mitigate: pembatasan permintaan dan pemantauan beban
TM-12	P2 (F3)	T	Parameter pencarian atau identifier produk dimanipulasi untuk meminta data yang tidak semestinya.	A-03 / R-12	2	4	8 Medium	Mitigate: validasi input dan pembatasan akses data

Baris TM-01 dan AS-01 adalah contoh format. Isi seluruh baris dengan temuan Anda sendiri.

Refleksi

Tulis 3-4 kalimat: apa yang dapat ditemukan threat modeling pada fase desain yang sulit ditemukan setelah kode selesai?

Threat modeling pada fase desain dapat membantu menemukan potensi ancaman keamanan sejak awal, seperti risiko pencurian akun, kebocoran token autentikasi, dan perubahan data pesanan tanpa izin. Selain itu, threat modeling membantu mengidentifikasi titik masuk sistem, aliran data, dan batas kepercayaan yang berisiko sebelum aplikasi selesai dibuat. Jika ditemukan setelah kode selesai, perbaikan dapat membutuhkan lebih banyak waktu dan biaya karena harus mengubah kode yang sudah ada. Oleh karena itu, threat modeling penting untuk merancang sistem yang lebih aman sejak awal.